

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN

BẢN THẢO TIỂU LUẬN TÍCH LŨY

HỌC PHẦN: BẢO MẬT IoT (INT4410)

ĐỀ TÀI: RỦI RO THIẾT BỊ IOT KẾT NỐI TRỰC TIẾP
INTERNET

Mã đề tài	29
Hướng đề tài	Hướng D
Sinh viên	Phạm Thị Tường Vi
Mã số sinh viên	231A010502
Lớp học phần	253INT441001
Giảng viên	ThS. Hồ Nhật Minh
Link repo GitHub	https://github.com/TuongVi220/de-tai-29-rui-ro-iot-ket-noi-internet
Ngày nộp	3/8/2026

TP. HỒ CHÍ MINH, 2026

PHẦN A. KIỂM TRA TRẠNG THÁI HOÀN THÀNH

Nội dung	Trạng thái	Minh chứng
Chương 1: Tổng quan	☒ Đạt	Viết đủ 1.1-1.6
Chương 2: Cơ sở lý thuyết	☒ Đạt	Khái niệm STRIDE, Nmap, Wireshark
Chương 3: Phương pháp & Thiết kế	☒ Đạt	Kiến trúc hệ thống giả lập bằng Python
Chương 4: Triển khai & Kết quả	☒ Đạt	Log thực nghiệm 3 kịch bản tấn công
Chương 5: Đánh giá bảo mật	☒ Đạt	Ma trận rủi ro & Checklist cấu hình (VPN)
Chương 6: Kết luận	☒ Đạt	Tổng kết đề tài
Kho lưu trữ (Repository)	☒ Đạt	Đã đồng bộ đầy đủ mã nguồn và README

PHẦN B. NỘI DUNG CHI TIẾT

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Trong kỷ nguyên Internet vạn vật (IoT), IP Camera đang được sử dụng rộng rãi. Tuy nhiên, để tiện lợi cho việc giám sát từ xa, nhiều người dùng có thói quen thiết lập tính năng Port Forwarding (NAT) trên Router, đẩy IP Camera tiếp xúc trực tiếp với Internet. Sự bất cẩn này, kết hợp với mật khẩu mặc định và giao thức HTTP không mã hóa, tạo điều kiện thuận lợi cho tin tặc dễ dàng tiếp cận. Do đó, việc nghiên cứu các rủi ro này là hết sức cấp thiết.

1.2. Phát biểu vấn đề bảo mật

Tài sản cần bảo vệ: Dữ liệu video giám sát cá nhân. Mối đe dọa chính là việc thiết bị hỗ trợ dịch vụ kết hợp giao thức truyền tải văn bản thuần túy (HTTP) không mã hóa và xác thực yếu. Hậu quả là tin tặc có thể thu thập thông tin tình báo (Scanning), đánh hơi thông tin tài khoản (Sniffing) và bẻ khóa mật khẩu (Brute-force), xâm phạm quyền riêng tư nghiêm trọng.

1.3. Mục tiêu của đề tài

- Mô phỏng thành công quy trình tìm kiếm thiết bị IoT bị lộ trên mạng.
- Đánh giá rủi ro đánh hơi gói tin khi giao tiếp bằng HTTP không mã hóa.
- Kiểm chứng rủi ro bị vét cạn mật khẩu đối với tài khoản mặc định.

- Xây dựng Checklist phòng thủ an toàn qua cấu trúc VPN/VLAN.

1.4. Đối tượng, phạm vi và giới hạn an toàn

Đề tài tập trung phân tích đối tượng IP Camera. Phạm vi thực nghiệm: Không tấn công hệ thống thật trên Internet. Toàn bộ kịch bản (Nmap, Wireshark, Burp Suite) được triển khai khép kín trên môi trường Localhost thông qua một Web Server Python giả lập IP Camera.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc kỹ thuật của hệ thống

Hệ thống bao gồm: IP Camera, Router mạng gia đình (NAT/Port Forwarding) và Internet. Ranh giới tin cậy nằm ở Router: khi Port Forwarding được kích hoạt, IP Camera bị đẩy ra khỏi ranh giới an toàn (LAN).

2.2. Khái niệm bảo mật trực tiếp liên quan

- **Port Scanning:** Gửi gói tin để xác định cổng dịch vụ mở (Nmap).
- **Packet Sniffing:** Đánh hơi lưu lượng mạng truyền qua lại để phân tích nội dung (Wireshark).
- **Brute-force Attack:** Tấn công bẻ khóa mật khẩu bằng cách thử liên tục (Burp Suite).
- **Mô hình STRIDE:** Phương pháp phân tích mối đe dọa do Microsoft phát triển.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Nghiên cứu sử dụng phương pháp luận tấn công hộp đen (Black-box) kết hợp giả lập môi trường cục bộ để đo lường các lỗ hổng của IP Camera. Các công cụ kiểm thử bảo mật tiêu chuẩn được áp dụng theo trình tự: Rà quét -> Nghe lén -> Bẻ khóa.

3.2. Mô hình/Kiến trúc đề xuất

Thay vì sử dụng IP Camera vật lý, một máy chủ Web cục bộ được viết bằng Python (chạy cổng 8081) sẽ đóng vai trò là "nạn nhân". Máy chủ này yêu cầu xác thực bằng cơ chế Basic Authentication (chưa mã hóa) tương tự các camera cũ trên thị trường.

3.3. Môi trường, công cụ và dữ liệu

Môi trường: Windows Localhost. Công cụ: Python 3.10+, Nmap (Zenmap), Wireshark (bắt card Loopback), Burp Suite Community Edition.

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Kịch bản bắt đầu bằng việc kích hoạt script fake_camera.py, thiết bị sẽ mở cổng mạng 8081 và chờ luồng kết nối HTTP đến.

4.2. Kịch bản thử nghiệm 1: Quét mạng (Port Scan) bằng Nmap

Sử dụng Nmap quét dải IP localhost. Kết quả thực nghiệm trả về log: 8081/tcp open http. Điều này chứng minh bất kỳ ai trên mạng đều có thể phát hiện camera đang trực tuyến.

4.3. Kịch bản thử nghiệm 2: Bắt gói tin (Sniffing) bằng Wireshark

Mở Wireshark lắng nghe giao diện Loopback. Người dùng đóng vai nạn nhân tiến hành đăng nhập vào trình duyệt bằng tài khoản "admin". Lọc luồng dữ liệu HTTP (Follow TCP Stream), kết quả trả về gói tin chứa chuỗi lộ lọt: Authorization: Basic YWRtaW46YWRtaW4=. Base64 hoàn toàn có thể giải mã thành chữ rõ trong 1 giây.

4.4. Kịch bản thử nghiệm 3: Vét cạn mật khẩu (Brute-force) bằng Burp Suite

Sử dụng module Intruder của Burp Suite, nạp danh sách 100 mật khẩu yếu phổ biến kèm luật mã hóa Base64 tự động. Kết quả: Thiết bị không có cơ chế rate limiting (giới hạn số lần thử nghiệm). Gói tin thử nghiệm "admin:admin" trả về mã trạng thái HTTP 200 OK ngay lập tức, báo hiệu hacker đã bẻ khóa thành công.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT VÀ ĐỀ XUẤT GIẢI PHÁP

5.1. Ma trận rủi ro

Đánh giá mức độ rủi ro: Kỹ thuật Sniffing qua mạng Wi-Fi và Brute-force có Điểm rủi ro ở mức RẤT CAO (Mức 5 - Tác động mất hoàn toàn quyền riêng tư). Cơ sở hạ tầng hiện tại không đủ sức phản kháng nếu đối mặt với botnet.

5.2. Biện pháp giảm thiểu (Giải pháp phòng thủ)

Kiến trúc bảo vệ (Giải pháp đề xuất): Xóa bỏ hoàn toàn Port Forwarding (NAT) trực tiếp. Khuyến nghị người dùng xây dựng đường hầm mã hóa mạng riêng ảo (VPN Server) đặt tại biên mạng kết hợp chia mạng nội bộ (VLAN) chuyên dụng cho thiết bị IoT.

5.3. Checklist cấu hình an toàn

- Tắt UPNP và Port Forwarding trên Router mạng gia đình.
- Thay đổi mật khẩu mặc định ngay lần đầu truy cập thành chuỗi dài trên 12 ký tự.
- Bắt buộc truy cập Camera từ xa thông qua ứng dụng VPN (WireGuard/OpenVPN).
- Sử dụng giao thức HTTPS/TLS để quản lý cấu hình camera nếu thiết bị có hỗ trợ.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đề tài đã hoàn thành xuất sắc mục tiêu đề ra: Xây dựng thành công hệ thống giả lập lỗ hổng trên IP Camera, tiến hành kiểm thử thực chiến 3 rủi ro cốt lõi và đo lường được hậu quả. Từ đó, bộ giải pháp VPN/VLAN được chứng minh là cấp thiết để cách ly thiết bị IoT khỏi các rủi ro từ Internet.

6.2. Hướng phát triển

Tương lai có thể nghiên cứu ứng dụng Trí tuệ nhân tạo (AI) tích hợp vào hệ thống phát hiện xâm nhập (Suricata IDS) để cảnh báo hành vi Brute-force ngay trên luồng lưu lượng IoT.

LỜI CAM ĐOAN

Em xin cam đoan đề tài tiểu luận "**Rủi ro thiết bị IoT kết nối trực tiếp Internet**" (Mã đề tài: 29) là công trình nghiên cứu và thực hành độc lập của cá nhân em dưới sự hướng dẫn chuyên môn của ThS. Hồ Nhật Minh. Các số liệu, kết quả thực nghiệm (log Nmap, Wireshark, Burp Suite) nêu trong báo cáo là hoàn toàn trung thực, được thực hiện trên môi trường giả lập cục bộ (Localhost) và không sao chép từ bất kỳ nguồn nào mà không có trích dẫn rõ ràng.

Mọi tài liệu tham khảo, các công cụ sử dụng trong quá trình nghiên cứu đều được ghi nhận rõ nguồn gốc tại phần Tài liệu tham khảo. Các kịch bản kiểm thử bảo mật tuân thủ tuyệt đối quy định đạo đức nghề nghiệp, không thực hiện tấn công vào bất kỳ hệ thống thực tế nào trên môi trường Internet. Em xin chịu hoàn toàn trách nhiệm trước Hội đồng môn học, Khoa Công nghệ Thông tin và Trường Đại học Văn Hiến về lời cam đoan này.

TP. Hồ Chí Minh, ngày 03 tháng 08 năm 2026

Sinh viên thực hiện



Phạm Thị Tường Vi